

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC102

Week 3 Assignment

Security Governance: Roles, Responsibilities and Real-World Application

Cross-Functional Governance + Research + NDPC Data Analysis

Name	Adeshola Oluwole
Registration Number	C1126CGRCE17211
Course	GRC102 – Information Security Governance
Module	Module 3 – Roles and Responsibilities in Security Governance
Week	Week 3: 19–25 September 2026
Opens	19 September 2026, 8:00 AM WAT
Due	25 September 2026, 11:59 PM WAT
Closes	27 September 2026, 11:59 PM WAT
Maximum Score	100 marks
Effective Course Contribution	8.75% of final course grade

Submission mode: Combined evidence — written report + supporting analysis workbook

Required resource: GRC102 Week 3 NDPC Security Incidents Enhanced workbook (included in the student package)

1. Assignment Overview

Effective security governance depends on clearly defined authority, accountability, cross-functional collaboration and evidence-based oversight. In this assignment, you will move beyond describing governance concepts and build a practical operating model that shows how the Board, executive management, the CISO, the CRO, Legal, Finance, Human Resources, IT and Risk should work together.

You will also examine the evolving role of the CISO, analyse a recent major security incident from a governance perspective, and use a simulated NDPC security-incident dataset to identify patterns that should influence governance decisions, escalation and control improvement.

2. Learning Outcomes

- Define the governance responsibilities of key Board, executive, risk, legal, finance, HR and technology stakeholders.
- Use RACI and segregation-of-duties principles to clarify accountability for security governance activities.
- Design escalation and decision paths for material cyber-risk issues.
- Evaluate how the CISO role and reporting structure have evolved under increased Board and regulatory scrutiny.
- Analyse a major security breach as a governance failure rather than only a technical incident.
- Use quantitative incident data to assess control effectiveness, operational performance and governance risk.
- Translate evidence into concise Board/CISO recommendations and measurable governance actions.

3. Assignment Scenario

You have been appointed Lead Security Governance Adviser to a large, rapidly evolving organisation. Senior leadership recognises that security can no longer be treated as an IT-only responsibility. Legal, Finance, HR, Risk, IT and executive leadership must work together under a defined governance model, while the Board requires clear visibility of material cyber risk and assurance that incidents are being managed effectively.

Your assignment is to create a cross-functional governance responsibility model, demonstrate how conflicts and escalations should be handled, research contemporary governance practice, and use the accompanying National Digital Protection Corporation (NDPC) dataset to develop evidence-based recommendations.

4. Part A — Cross-Functional Governance Responsibility Model (30 marks)

Develop a security governance operating model that makes accountability explicit and prevents security decisions from being left solely to the IT department.

A1. Governance Roles and Responsibilities

- Board of Directors / relevant Board committee
- Chief Executive Officer (CEO)
- Chief Information Security Officer (CISO)
- Chief Risk Officer (CRO) or enterprise risk function
- Legal / Privacy / Compliance
- Finance
- Human Resources
- Information Technology / Technology Operations

For each role, define its decision authority, accountability, consultation responsibilities, reporting expectations and relationship to the other governance stakeholders.

A1. Governance Roles and Responsibilities

A security governance operating model has been developed in a tabular form below so as to make accountability explicitly stated and to prevent security decisions from being solely confined to the IT department. As a result of this, the security governance operating model will be based on five (5) things which are the decision authority, accountability, consultation responsibilities, reporting expectations and relationship to the other governance stakeholders.

Roles / Responsibility	Decision Authority	Accountability	Consults	Reporting	Relationship
Board of Directors / Board Committee	The board or board committee is responsible for the security strategy and budget allocations and holds the risk acceptance authority and approves the enterprise risk appetite or tolerance.	Accountable to shareholders/regulators for the organization to have <i>adequate</i> governance not for day-to-day security	Consults CISO and CRO for risk posture briefings, Consults legal for regulatory exposure and consults external auditors for independent assurance.	Receives quarterly security briefings and immediate notification of material incidents	Sits above the CEO in authority; delegates execution to CEO/CISO but cannot delegate away ultimate accountability.
CEO	Defines the security governance structure and reporting lines, approves resource allocation within Board-set budgets, makes final crisis-leadership calls during major incidents.	Accountable to the Board for translating strategy into execution and for organizational security culture.	CISO and CFO before major resourcing decisions; Consults Legal/Communications during a crisis.	Reports to the Board	The hinge between Board direction and executive execution

CISO	The CISO owns the security strategy and policy framework, approves security architecture standards	The CISO is accountable for the organization's actual security posture, incident response effectiveness, and accurate risk reporting to leadership.	CISO consults IT/Engineering on feasibility Consults Legal on regulatory interpretation. Consults HR on personnel-related security issues. Consults Finance on budget related affairs.	Reporting to CIO risks security being subordinated to delivery speed; reporting to CEO or the Board directly gives more independence and visibility but can lose IT operational context.	The central connects up to Board/CEO, sideways to CRO/Legal/Finance/HR, and down to IT/security operations.
CRO / Enterprise Risk Function	Approves the risk assessment methodology	Accountable for enterprise-wide risk visibility by ensuring cyber risk is assessed using the same measure as that of financial or operational risk and not treated as an IT-only category alone.	Consults CISO for cyber-specific risk data, Consults Legal for compliance risk, Consults Finance for financial related matters.	Reports to CEO and/or directly to the Board Risk Committee — this dual line is deliberate, so risk reporting isn't filtered solely through the people whose performance it might reflect on.	Provides the "second line of defense" function — the first line (operational management) owns and manages risk, the second line (risk management and compliance) oversees it, and the third line (internal audit) gives independent assurance.
Legal, Privacy and Compliance	Determines regulatory breach-notification obligations and timing, approves external communications during a breach for legal exposure, interprets contractual/regulatory security requirements.	Accountable for the organization not incurring unnecessary legal/regulatory liability, and for meeting statutory deadlines (e.g., 72-hour breach notification under GDPR-style regimes).	Consults CISO on technical facts of an incident before making legal characterization s, Consults Finance on financial exposure from fines and HR on employee-data matters.	Reports to CEO/General Counsel; escalates directly to Board on material regulatory exposure.	Gatekeeper between "what happened" (CISO's domain) and "what we're legally required to say/do about it."
Finance	Approves/allocates the security budget, decides on cyber-insurance coverage and limits, quantifies financial impact of incidents for reporting.	Accountable for ensuring security spend is proportionate to risk and properly reflected in financial disclosures (material incidents can be disclosure events).	Consults CISO on what budget achieves, Legal on disclosure obligations and CRO on priority based risk-adjusted investment.	Reports to CEO/CFO chain and informs Audit Committee on financial statement impact of incidents.	Controls the resource lever that determines what the CISO can actually execute

HR	Approves security-awareness training curricula, decides on disciplinary action for policy violations, controls onboarding/offboarding access-provisioning triggers.	Accountable for the employees layer of security and that awareness programs are actually delivered.	Consults CISO on what constitutes a violation worth disciplining; Consults Legal on employment-law constraints on disciplinary action or monitoring.	Reports to CEO; reports security-culture metrics into governance committees.	Executes a lot of what CISO/Legal <i>decide</i> for instance, losing of employees access.
Information Technology	Makes implementation decisions for approved controls, manages day-to-day system configuration, decides technical remediation	Accountable for operational uptime <i>and</i> for correctly implementing controls the CISO's policies require	Consults CISO on control specifications	Reports to CIO (or CTO); CISO reports up a <i>separate</i> line specifically so IT isn't grading its own security homework.	The "first line of defense" — operational management that owns and manages risk directly, with CISO/CRO as oversight (second line).

A2. RACI Matrix

Create a RACI matrix covering at least 10 security-governance activities. At minimum, include:

- Security strategy approval
- Enterprise cyber-risk acceptance
- Information security policy approval
- Major incident response governance
- Regulatory breach notification
- Privileged access approval
- Third-party cyber-risk acceptance
- Security awareness and disciplinary action
- Cybersecurity budget prioritisation
- Board cyber-risk reporting

The below table shows the RACI Matrix of 10 security-governance activities with respect to the roles and responsibilities of the Board, CEO, CISO, CRO, Legal, Finance, HR and IT

Security Governance Activity	Board	CEO	CISO	CRO	Legal	Finance	HR	IT
Security Strategy Approval	A	C	R	C	I	I	I	I
Enterprise Cyber-Risk Acceptance	I	I	R	A	C	C	I	I
Information Security	I	I	A	I	C	I	I	C

Policy Approval			R					
Major Incident Response Governance	I	A	R	I	C	I	I	C
Regulatory Breach Notification	I	C	C	I	A R	I	I	I
Privileged Access Approval	I	I	A	I	I	I	C	R
Third party Cyber Risk Acceptance	I	I	R	A	R	C	I	C
Security Awareness and Disciplinary Action	I	I	R	I	C	I	A R	C
Cybersecurity budget Prioritisation	I	C	R	C	I	A	I	I
Board Cyber Risk Reporting	I	A	R	C	C	I	I	I

The above RACI matrix explains the following:

- That strategy approval sits with the board and not the CISO
- Enterprise risk acceptance is CRO's call, not CISO's
- Breach notification is the Legal's call and not the CISO's
- Major incident response governance is CEO-accountable, CISO-responsible.
- Disciplinary action sits with HR, not CISO
- It should also be noted that anywhere CISO is Accountable, its is for security's technical or policy domain such as privileged access or policy content
- Anywhere the decision has legal, financial or enterprise risk effects that goes beyond security, the accountability shifts to the CRO, Legal, Finance or the CEO/Board.

A3. Segregation of Duties and Conflict Resolution

- Identify at least three realistic conflicts of responsibility or segregation-of-duties risks.
- Explain why each conflict creates governance, fraud, compliance or operational risk.
- Define a practical control for resolving each conflict without creating unnecessary bureaucracy.

A3.1 Three (3) realistic conflicts of responsibility or segregation-of-duties risks

- ✓ IT owns both system uptime *and* security control implementation
- ✓ Privileged access administration and privileged access auditing sit with the same function
- ✓ CISO recommends security budget priorities *and* would be the one whose program looks better funded

A3.2 Reasons why the 3 realistic conflicts of responsibility or segregation-of-duties risks creates governance, fraud, compliance or operational risk

- ✓ IT is responsible for both keeping systems up and implementing the CISO's security controls, but those two goals often clash — patching can cause downtime, and security measures like MFA can lock users out during critical work — so when the same team is judged on uptime and also controls the security enforcement, uptime tends to quietly win.
- ✓ If the same team that creates and manages admin access is also the one checking how that access was used, they're essentially auditing themselves.
- ✓ Finance is accountable for prioritizing the budget and the CISO acts as responsible / advisor — but if Finance just approves whatever the CISO asks for without any independent review, then the person requesting the resources is effectively also approving them. It's the same self-review issue, just with budget instead of access.

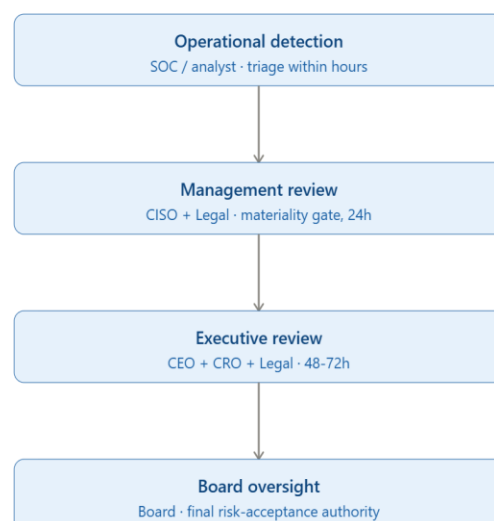
A3.3 Practical controls for resolving each conflict without creating unnecessary bureaucracy

- ✓ Any exception or delay to a security control should be logged, time-boxed, and signed off by the CISO and should not be allowed to be quietly decided by IT alone.
- ✓ Privileged access should be reviewed quarterly by someone outside the team that manages it such as the Internal Audit but never IT reviewing itself.
- ✓ Material security budget requests should go through a joint review by Finance and the CRO with the CRO itself validating that the risk being funded is actually material before it goes to the Board.

In Conclusion, it is important to note that the person or the team who executes a decision is not the only reviewer of the decision. That is Segregation of Duties.

A4. Material Cyber-Risk Escalation Path

Design an escalation workflow showing how a material cyber-risk issue moves from operational detection through management review to executive and Board oversight. Your workflow must identify trigger criteria, decision points, responsible roles, required evidence, escalation timing and final risk-acceptance authority.



A5. Cross-Functional Failure Scenario

Analyse one realistic scenario in which poor coordination between Legal, Finance, HR, Risk and IT could create regulatory, financial or operational consequences. Conclude with at least five recommendations for improving accountability and collaboration.

A5 The Scenario: A third-party data exposure that stalls at the coordination layer

A payroll vendor used by HR suffers a cyberattack, exposing employees' personal and banking information. The incident is not handled properly because each department treats it as someone else's responsibility.

IT: IT notices unusual data activity from the vendor but considers it a vendor issue. The team closes the alert without informing the CISO or Legal. This shows a failure in operation detection, because the escalation process did not clearly cover third-party incidents.

HR: HR later receives the vendor's breach notification but treats it as a normal vendor-management issue. HR does not escalate it because the connection between vendor incidents and the cyber-incident process was unclear.

Legal: Legal is informed much later. This delays the assessment of regulatory reporting requirements and increases the risk of missing notification deadlines.

Finance: Finance only becomes involved after employees report fraudulent activity and request compensation. The potential costs and insurance implications were therefore not assessed early.

Risk/CRO: The CRO does not receive the full picture because information remains divided between the different departments. This prevents an effective assessment of the wider third-party risk.

Root Cause of the Incident

The main problem was not that one department failed to do its job, rather it was that the escalation process focused mainly on **internal technical incidents** and did not clearly state how a breach involving a third-party vendor should be handled.

Consequences

- ✓ **Regulatory:** Delayed reporting may result in additional compliance issues or penalties.
- ✓ **Financial:** Unexpected costs may arise from investigations, compensation, legal action and remediation.
- ✓ **Operational:** Employee trust may be affected, while HR has to manage concerns from affected employees.

Recommendations

- ✓ There is the need to update escalation triggers to include third-party and vendor-reported security incidents.
- ✓ Clear ownership should be assigned for receiving and escalating all vendor security notifications.

- ✓ HR and other vendor owners are required to notify the CISO within 24 hours of receiving a security notice.
- ✓ Finance should be involved early enough to assess possible financial losses and insurance coverage for critical vendors.
- ✓ An annual tabletop exercise should be conducted involving IT, HR, Legal, Finance and Risk to test the escalation process.

5. Part B — The CISO, Board and Contemporary Governance (20 marks)

Conduct focused research using credible sources such as official framework documentation, regulator publications, industry reports and peer-reviewed or reputable professional material.

- Explain how the CISO role has evolved over approximately the last decade.
- Discuss how CISO reporting lines, independence and access to the Board affect governance effectiveness.
- Explain how regulatory scrutiny, executive accountability and business dependence on digital services have changed CISO responsibilities.
- Provide at least one publicly documented example showing how CISO leadership or governance decisions positively or negatively affected an organisation's security posture.
- Conclude with your recommended CISO governance model for a large organisation and justify it.

Recommended length for Part B: approximately 800–1,000 words, excluding references.

The CISO, Board and Contemporary Governance

How the CISO role has evolved over the last decade

The role of the Chief Information Security Officer (CISO) has changed considerably over the past ten years. In the past, the CISO was mainly seen as a technical expert who worked within the IT department and usually reported to the CIO. Because of this, security was often treated as an IT issue rather than something that needed regular attention from senior management and the board.

This situation has gradually changed as organisations have become more dependent on digital systems and have faced more serious cyber risks. CISOs are now becoming much more involved in business and strategic decisions. Recent industry research shows how quickly this change has happened. The proportion of CISOs reporting directly to CEOs reportedly increased from 47% in 2023 to 82%, while 83% now attend board meetings regularly. The responsibilities of the role have also expanded. CISOs are increasingly involved in areas such as infrastructure, fraud, physical security and artificial intelligence, rather than focusing only on traditional information security. This shows that cybersecurity is now closely connected to wider business risks and organisational decision-making.

Reporting lines, independence and governance effectiveness

The person a CISO reports to can have a significant effect on how effectively security risks are managed. If the CISO reports to the CIO, there is usually a strong connection between security and day-to-day IT operations. However, there can also be a risk that business or technology delivery priorities receive more attention than security concerns.

On the other hand, having the CISO report directly to the CEO or a board committee can provide greater independence. It can also make it easier for important security risks to reach senior decision-makers without being filtered through the IT department. This does not mean that reporting directly to the board is automatically the right arrangement for every organisation. The CISO still needs a good understanding of the organisation's technology environment and must work closely with the CIO and other technical teams.

For this reason, the reporting structure should be designed to give the CISO enough independence to raise concerns while still maintaining close operational cooperation with IT. This is particularly important because security risks often need to be considered before major business decisions are made, rather than simply reported after something has gone wrong.

The effect of regulation and digital dependence on the CISO role

Regulatory requirements have also changed what is expected from CISOs. Organisations are now under greater pressure to identify, assess and report significant cybersecurity incidents accurately and within specific timeframes. A good example is the SEC's 2023 cybersecurity disclosure rules, which require affected public companies to disclose material cybersecurity incidents within four business days.

These requirements have increased the pressure on CISOs because cybersecurity decisions can now have legal and financial consequences beyond the technical department. A CISO may be involved in determining the seriousness of an incident, but the information provided can also become part of a company's public disclosure.

This has raised concerns within the profession about where individual responsibility should end and organisational responsibility should begin. Some CISOs have therefore started seeking stronger contractual protection, including indemnification and appropriate Directors and Officers (D&O) insurance. Clear responsibilities are important because a cybersecurity incident is normally the result of several organisational factors rather than the actions of one individual.

SolarWinds and CISO Timothy Brown

The SEC's case involving SolarWinds and its CISO, Timothy Brown, provides a useful example of why these governance issues matter. In 2024, the SEC filed an amended complaint against SolarWinds and Brown, alleging that the company had made misleading statements about its

cybersecurity practices and had failed to properly disclose information relating to the SUNBURST cyberattack.

The case attracted considerable attention because it involved an individual CISO in addition to the company itself. It raised concerns among security professionals about whether CISOs could personally face regulatory consequences because of statements made by their organisations.

However, the case was later narrowed by the courts. In July 2024, a federal judge dismissed most of the SEC's claims, although some claims relating to statements made before the breach were allowed to continue. In November 2025, the SEC agreed to dismiss the remaining claims against SolarWinds and Brown with prejudice.

The main governance lesson from the case is not simply about the actions of the CISO. It demonstrates the importance of having clear processes for reviewing public cybersecurity statements. Security information prepared by the CISO may need to pass through Legal, Investor Relations and other relevant functions before it is communicated publicly. Without this process, there is a risk that the technical assessment of the CISO and the organisation's public statements do not fully match.

This is also connected to the accountability issues considered in Part A. Clearly defining who is responsible for assessing, approving and communicating cybersecurity information can reduce confusion when an incident occurs.

Recommended CISO governance model

For a large organisation, I would suggest a governance structure that gives the CISO sufficient independence while maintaining a strong relationship with IT. One option would be for the CISO to report to the CEO or the Board Risk Committee, with a secondary reporting relationship to the CIO for operational matters.

There should also be a formal review process involving the CISO, Legal and Investor Relations before important cybersecurity or risk information is released publicly. This would help ensure that technical findings are accurately represented and that the organisation meets its disclosure obligations.

The organisation should also provide appropriate D&O insurance and indemnification for the CISO, alongside clearly defined responsibilities. Finally, the CISO should provide cybersecurity updates to the board at least quarterly, while serious incidents that meet the organisation's materiality or escalation criteria should be reported immediately.

Overall, the changing role of the CISO shows that cybersecurity can no longer be treated as an issue belonging only to the IT department. The CISO now sits much closer to strategic decision-making, which makes clear reporting lines, accountability and communication between security, legal, management and the board increasingly important.

6. Part C — Major Security Breach Governance Case Study (20 marks)

Select a publicly documented major security breach or ransomware incident disclosed between 2023 and 2026. Analyse the event from a security-governance perspective rather than focusing only on technical indicators.

- Provide a concise overview of the incident and its business impact.
- Describe what is publicly known about the organisation's governance, accountability and risk-management arrangements before the incident.
- Identify at least five governance weaknesses or failures that may have contributed to the incident or increased its impact.
- Assess the roles of the Board, executive leadership, CISO/security function and relevant business units.
- Discuss material regulatory, legal, financial or reputational consequences.
- Recommend governance improvements that could reduce the likelihood or impact of a similar incident.

Major Security Breach Governance Case Study

Change Healthcare / UnitedHealth Group (February 2024)

Incident overview and business impact

On 21 February 2024, Change Healthcare, a subsidiary of UnitedHealth Group and one of the largest healthcare payment-processing companies in the United States, suffered a ransomware attack linked to the ALPHV/BlackCat group. The company processes around 15 billion healthcare transactions each year and its systems are connected to a large part of the US healthcare system. As a result, the attack caused serious disruption across the country. Pharmacies struggled to process prescriptions, hospitals experienced problems with insurance claims, and many healthcare providers faced delays in receiving payments.

The attackers had gained access to Change Healthcare's systems nine days before the ransomware was deployed, on 12 February. During this period, they were able to steal data before launching the ransomware. UnitedHealth later reported that the incident affected the protected health information of up to 192.7 million people, making it the largest healthcare data breach reported at the time. The company also confirmed that a \$22 million ransom was paid through its Optum subsidiary in an attempt to have the stolen information deleted. By the third quarter of 2024, UnitedHealth reported that the overall financial impact of the cyberattack had reached approximately \$2.457 billion.

What was publicly known about governance before the incident

The Change Healthcare attack provides some useful information about the security weaknesses that existed before the incident. In May 2024, UnitedHealth CEO Andrew Witty testified before Congress and explained that the attackers gained access using stolen credentials through a Citrix remote access portal that did not have multi-factor authentication (MFA) enabled.

The attackers had access for about nine days before the ransomware was detected. This was also linked to issues following UnitedHealth's acquisition of Change Healthcare in 2022. The available information suggests that the security controls of the two organisations were not fully aligned after the acquisition. The Senate Finance Committee later requested several years of Change Healthcare's security audit reports to understand whether some of these risks had already been identified.

Main governance weaknesses

One major weakness was the lack of MFA on a critical remote-access system. For an organisation handling a large amount of healthcare payment information, this should have been treated as an important security requirement.

Another issue was the post-acquisition integration. When UnitedHealth acquired Change Healthcare, its security controls should have been reviewed and brought in line with the wider organisation's standards. The fact that important security gaps remained suggests that cybersecurity responsibilities during the integration were not fully effective.

The nine-day delay in detecting the attackers also raises concerns about monitoring and escalation. A stronger monitoring process may have identified the unusual activity earlier.

There was also a significant concentration risk. Change Healthcare was connected to a large part of the US healthcare payment system, meaning that an attack on the company could affect many other organisations. This shows why the Board and senior management need to consider the wider impact of cyber risks, not just the security of individual systems.

Roles and responsibilities

The incident raises questions about the level of oversight provided by the Board, particularly over Change Healthcare after the acquisition. Although CEO Andrew Witty later accepted responsibility and testified before Congress, the missing MFA control suggests that the existing governance process did not identify the weakness early enough.

The security team also had an important role. Basic controls such as MFA, monitoring and regular security testing should have been reviewed for critical systems. At the business-unit level, Change Healthcare's importance to the healthcare sector should also have resulted in greater attention to resilience and cybersecurity.

Consequences

The attack had major financial, operational and legal consequences. Healthcare providers and pharmacies experienced difficulties processing payments and claims, while UnitedHealth reported total costs of approximately \$2.457 billion, in addition to the \$22 million ransom payment.

The incident also resulted in federal investigations and multiple lawsuits. More importantly, it demonstrated how an attack on one major service provider can disrupt an entire industry.

Recommended governance improvements

To reduce the chance of a similar incident, organisations should make cybersecurity part of the acquisition process and set clear deadlines for newly acquired companies to meet basic security requirements such as MFA, patching and monitoring.

Critical subsidiaries should also receive additional oversight because of the larger impact their failure could have. Regular independent security testing should be carried out on important internet-facing systems, with serious findings reported to senior management and the Board.

Finally, there should be clear responsibilities for detecting and escalating major incidents. The Board should also have enough cybersecurity knowledge to question management about significant risks and understand whether important security issues are being properly addressed.

7. Part D — NDPC Data Analysis and GRC Application (30 marks)

The accompanying workbook contains a simulated dataset for the National Digital Protection Corporation (NDPC), a hypothetical multinational technology organisation. The dataset includes 180 simulated incident records covering 2024–2025 and additional governance context such as root cause, control domain, regulatory exposure, escalation level, third-party involvement and simulated resolution-SLA status.

D1. Required Core Analysis

- Calculate the total number of incidents and the distribution of incidents by Incident_Type.
- Determine the average Resolution_Time_Days by Severity.
- Calculate total Cost_Impact_USD by Department and by Responsible_Team.
- Identify the three Incident_Type categories with the highest average Cost_Impact_USD.
- Calculate the percentage of incidents with Status = Open or In Progress.
- Create at least two appropriate charts or graphs that communicate material findings clearly.

D2. Advanced Governance Analysis

- Analyse SLA_Breached patterns by Severity and Responsible_Team.
- Identify material Regulatory_Exposure patterns by Department or Incident_Type.
- Assess whether third-party involvement appears associated with higher severity, cost or escalation.
- Identify at least one Control_Domain that should receive increased governance attention and justify your conclusion with data.

D3. CISO / Board Insights

Based on your analysis, present the three most critical insights you would give the CISO. For each insight:

- State the finding clearly.
- Provide supporting data or a chart.
- Explain the governance significance.
- Identify the accountable or responsible role(s).

- Recommend a concrete action, owner and measurable success indicator.

Below is the summary of the completed Part D workbook in the excel sheet:

The Analysis_Template tab is filled in with concise, direct answers for all of D1, D2, and D3, exactly matching the brief's requirement rows.

D1. Core_Analysis tab — full tables plus charts for incident distribution by type, average resolution time by severity, cost by department and by team, top incident types by average cost, and status breakdown.

D2. Advanced_Analysis tab — SLA breach rate by severity and by team, escalation-level vs. SLA outcome, regulatory exposure patterns, third-party involvement analysis, and control-domain cost concentration.

D3. CISO_Insights tab — the three top findings, each with its own chart and a full breakdown of finding → governance significance → accountable role → recommended action → owner/success metric:

- ✓ **Critical/High-severity incidents breach SLA most often** (70–74%) despite resolving fastest in absolute terms — the Critical SLA target is only 3 days, therefore speed still is not meeting the commitment.
- ✓ **Third-party involvement carries a 41.7% cost premium** which echoes the vendor-coordination failure just as we have in the A5 scenario as above.
- ✓ **Insider Threat / privileged-access incidents are rare but cost 2.4x the overall average** as data-backed confirmation just as it is in the A3 segregation-of-duties concern as previously seen above.

These numbers are computed directly from the given dataset, and I have deliberately tied each D3 insight back to the specific Part A concept that it validates.

Reference List

- Anthropic. (2026). *Claude (Sonnet 5)* [Large language model]. <https://claude.ai>
- American Hospital Association. (2024). *Change Healthcare cyberattack underscores urgent need to strengthen cyber preparedness for individual health care organizations and as a field*. <https://www.aha.org/change-healthcare-cyberattack-underscores-urgent-need-strengthen-cyber-preparedness-individual-health-care-organizations-and>
- Axelos. (2019). *ITIL 4 foundation: ITIL 4 edition*. The Stationery Office.
- BlackFog. (2024). *The Change Healthcare ransomware attack: A landmark cybersecurity breach*. <https://www.blackfog.com/change-healthcare-landmark-cybersecurity-breach/>
- Congressional Research Service. (2024). *The Change Healthcare cyberattack and response: Considerations for policymakers* (IN12330). U.S. Congress. https://congress.gov/crs_external_products/IN/PDF/IN12330/IN12330.7.pdf
- Dark Reading. (2024, July 18). *Sizable chunk of SEC charges vs. SolarWinds dismissed*. <https://www.darkreading.com/application-security/solarwinds-charges-tossed-out-of-court-in-legal-victory-against-sec>
- Fitzgerald, T. (2020). *CISO COMPASS: Navigating cybersecurity leadership challenges with insights from pioneers*. CRC Press.
- Harvard Law School Forum on Corporate Governance. (2025, December 7). *SolarWinds dismissed: What the SEC's U-turn signals for cyber enforcement*. <https://corpgov.law.harvard.edu/2025/12/07/solarwinds-dismissed-what-the-secs-u-turn-signals-for-cyber-enforcement/>
- HIPAA Journal. (2025, August 6). *Nebraska AG's lawsuit against Change Healthcare survives motion to dismiss*. <https://www.hipaajournal.com/change-healthcare-responding-to-cyberattack/>
- Holland & Knight. (2024, June). *Change Healthcare cybersecurity incident: Financial impact and resulting litigation*. <https://www.hklaw.com/en/insights/publications/2024/06/change-healthcare-cybersecurity-incident-financial-impact>
- Holland & Knight. (2024, July). *SEC cyber enforcement update: Which way are the SolarWinds blowing?* <https://www.hklaw.com/en/insights/publications/2024/07/sec-cyber-enforcement-update-which-way-are-the-solarwinds-blowing>
- Hyperproof. (2025). *Understanding the Change Healthcare breach and its impact on security compliance*. <https://hyperproof.io/resource/understanding-the-change-healthcare-breach/>
- InformationWeek. (2024). *CISOs in 2025: Evolution of a high-profile role*. <https://www.informationweek.com/it-leadership/cisos-in-2025-evolution-of-a-high-profile-role>
- International Organization for Standardization. (2020). *ISO/IEC 27014:2020 — Information security, cybersecurity and privacy protection — Governance of information security*.

ISACA. (2019). *COBIT 2019 framework: Introduction and methodology*. ISACA.

k-logix. (2024). *The evolving role of the CISO*. <https://www.klogixsecurity.com/blog/the-evolving-role-of-the-ciso>

Kouns, J., & Minoli, D. (2011). *Information technology risk management in enterprise environments*. Wiley.

Maymi, F. J., & Harris, S. (2018). *CISSP all-in-one exam guide* (8th ed.). McGraw-Hill Education.

National CIO Review. (2025). *All charges dropped in the SEC's cybersecurity suit against SolarWinds*. <https://nationalcioreview.com/articles-insights/extra-bytes/all-charges-dropped-in-the-secs-cybersecurity-suit-against-solarwinds/>

National Institute of Standards and Technology. (2018). *Framework for improving critical infrastructure cybersecurity* (Version 1.1).

Nixon Peabody. (2025, November 12). *The Change Healthcare cybersecurity breach: Impact on healthcare providers*. <https://www.nixonpeabody.com/insights/alerts/2025/11/12/change-healthcare-cybersecurity-breach-impact-on-healthcare-providers>

Sprinto. (2024). *Six ways CISO role is changing in 2025 (and what to do about it)*. <https://sprinto.com/blog/six-ways-ciso-role-changing/>

Swanson, M., & Bowen, P. (2006). *NIST Special Publication 800-100: Information security handbook: A guide for managers*. National Institute of Standards and Technology.

The Institute of Internal Auditors. (2020). *The IIA's three lines model: An update of the three lines of defense*.

Vantedge Search. (2025). *From CISO to the board: Cyber accountability is here*. <https://www.vantedgesearch.com/resources/blogs-articles/from-ciso-to-the-board-cyber-accountability-is-here/>

Whitman, M. E., & Mattord, H. J. (2021). *Management of information security* (6th ed.). Cengage Learning.

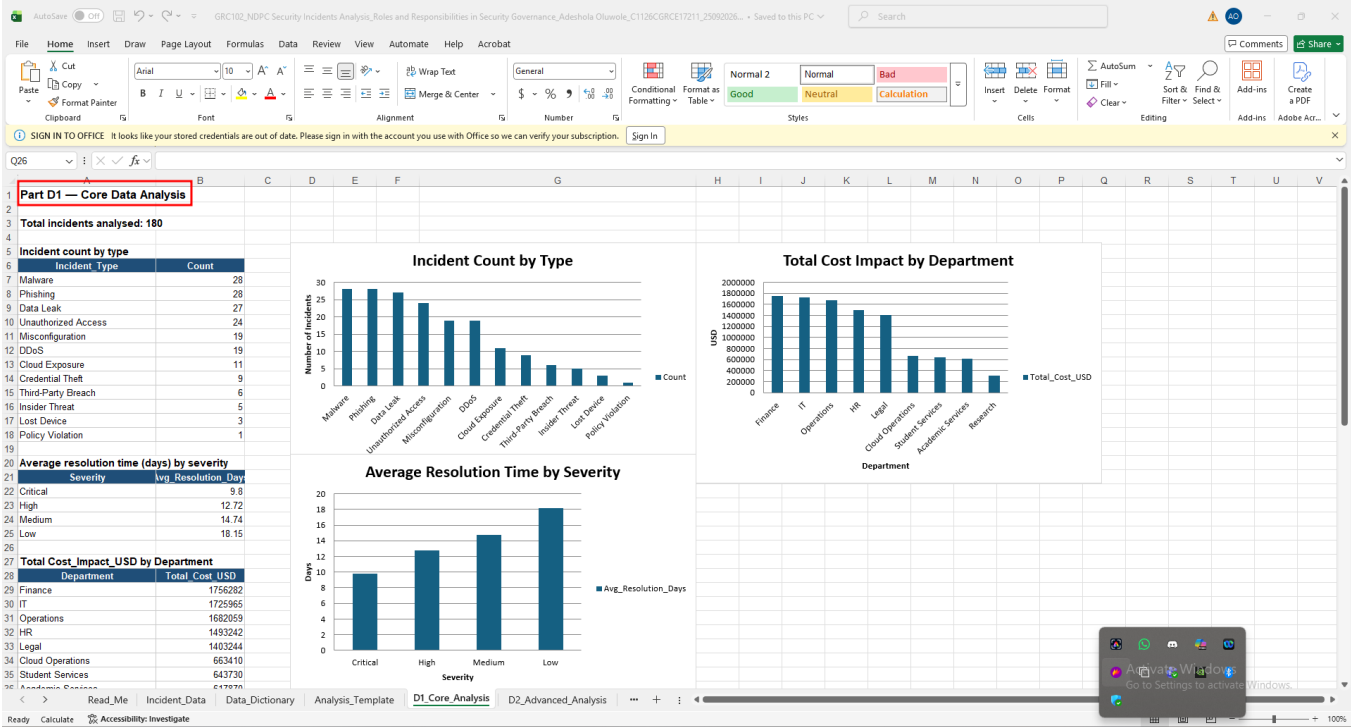
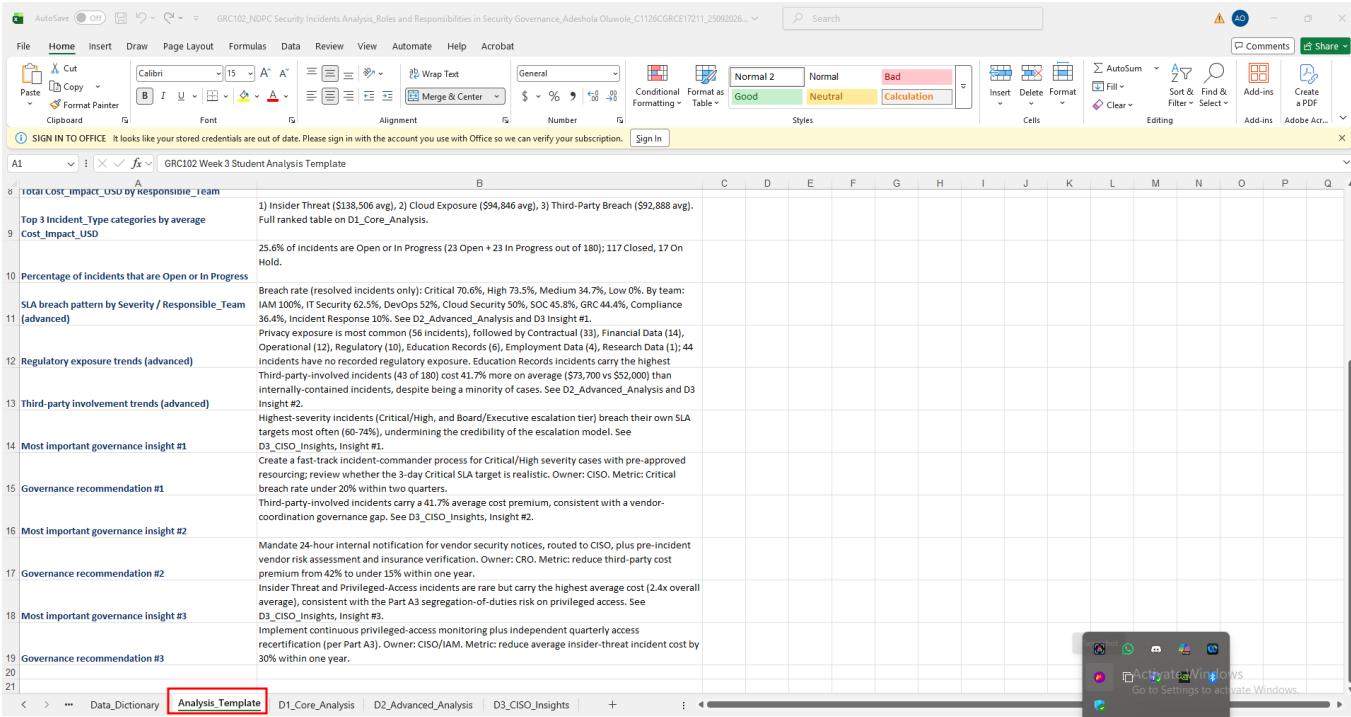
Appendix A — RACI Working Template

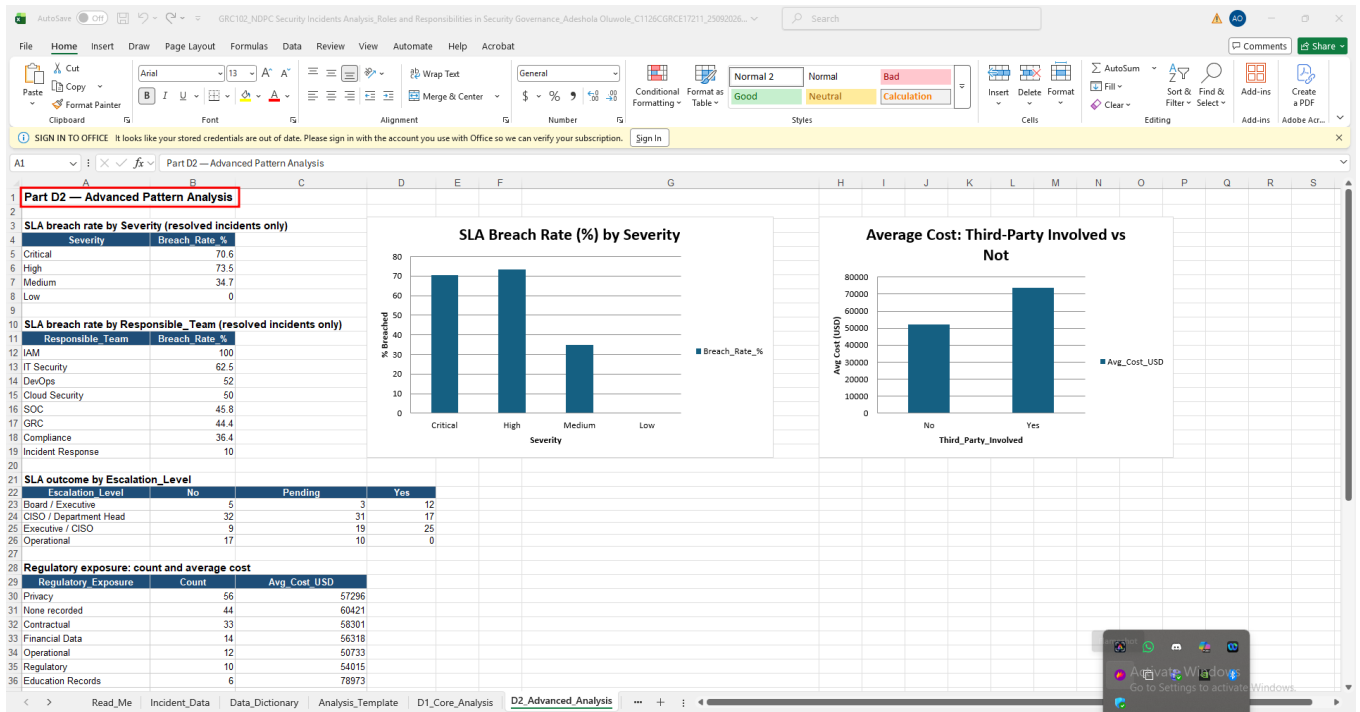
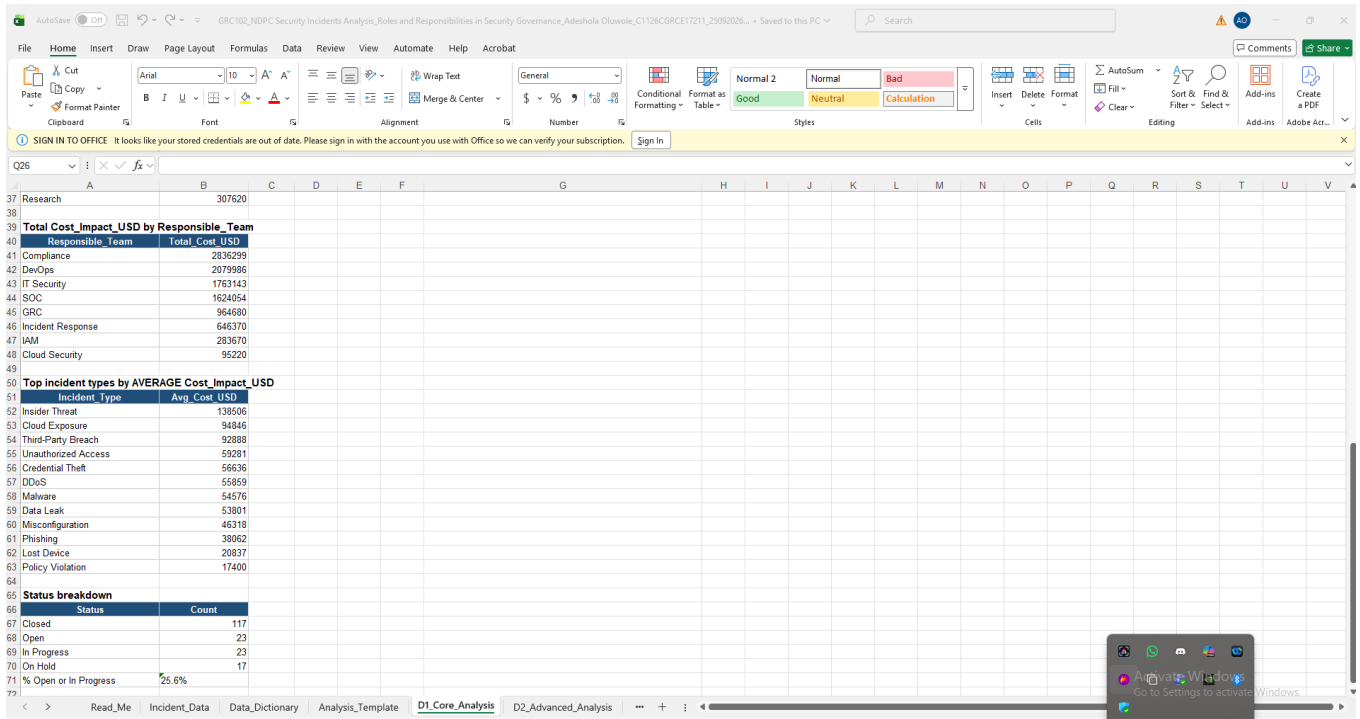
Use the structure below as a guide. Expand it to at least 10 governance activities and assign only one Accountable (A) role per activity unless you clearly justify an exception.

Governance Activity	Board	CEO	CISO	CRO / Risk	Legal	Finance	HR	IT
Security strategy approval								
Major incident governance								
Policy approval								
Enterprise cyber-risk acceptance								
Board cyber-risk reporting								

Appendix B — Data Analysis Evidence

The screenshot shows a Microsoft Excel spreadsheet titled "GRC102 Week 3 Student Analysis Template". The spreadsheet is a template for analyzing security incidents, with columns for various metrics and rows for different analysis requirements. The template includes instructions for students to use it as a planning workspace and to submit it as a substitute for written assignments unless instructed otherwise. The spreadsheet is divided into sections for Analysis Requirement, Your Notes / Result, and various metrics like Total number of Incidents, Distribution by Incident Type, Average Resolution Time, Total Cost Impact, and Percentage of incidents that are Open or In Progress. The spreadsheet is shown in a window titled "GRC102_NDPC Security Incidents Analysis_Roles and Responsibilities in Security Governance_Adeshola Oluwole_C1126GRC17211_25092026...".





AutoSave On | GRC102_NDPC Security Incidents Analysis_Roles and Responsibilities in Security Governance_Adehsala Oluwole_C1126GRC17211_25002026...

File Home Insert Draw Page Layout Formulas Data Review View Automate Help Acrobat

Clipboard Font Alignment Merge & Center Number Conditional Formatting Styles Cells Editing

SIGN IN TO OFFICE It looks like your stored credentials are out of date. Please sign in with the account you use with Office so we can verify your subscription. Sign In

Part D2 — Advanced Pattern Analysis

Escalation Level	No	Pending	Yes
Board / Executive	5	3	12
CISO / Department Head	32	31	17
Executive / CISO	9	19	25
Operational	17	10	0

Regulatory exposure: count and average cost

Regulatory Exposure	Count	Avg Cost USD
Privacy	56	57296
None recorded	44	60421
Contractual	33	58301
Financial Data	14	56318
Operational	12	50733
Regulatory	10	54015
Education Records	6	78973
Employment Data	4	18862
Research Data	1	15720

Third-party involvement vs. severity and cost

Third Party Involved	Count	Avg Cost USD
No	137	52002
Yes	43	73700

Control domain: count, average cost, total cost

Control Domain	Count	Avg Cost USD	Total Cost USD
Privileged Access & Monitoring	5	138596	692930
Cloud Security	11	94846	1043310
Third-Party Risk	6	92888	557330
Identity & Access Management	33	58560	1932469
Network Resilience	19	55859	1061329
Endpoint Security	28	54576	1528133
Data Protection	27	53801	1452637
Configuration Management	19	46318	880043
Security Awareness	28	38052	1065731
Asset & Endpoint Security	3	20837	62510
Policy Compliance	1	17400	17400

Read Me Incident Data Data Dictionary Analysis Template D1_Core_Analysis **D2_Advanced_Analysis**

AutoSave On | GRC102_NDPC Security Incidents Analysis_Roles and Responsibilities in Security Governance_Adehsala Oluwole_C1126GRC17211_25002026...

File Home Insert Draw Page Layout Formulas Data Review View Automate Help Acrobat

Clipboard Font Alignment Merge & Center Number Conditional Formatting Styles Cells Editing

SIGN IN TO OFFICE It looks like your stored credentials are out of date. Please sign in with the account you use with Office so we can verify your subscription. Sign In

Part D3 — Top 3 CISO Governance Insights

Insight #1: Highest-severity incidents breach SLA most often

Severity	Breach Rate %
Critical	70.6
High	73.5
Medium	34.7
Low	0

Finding

Critical incidents breach their SLA 70.6% of the time and High-severity incidents 73.5% of the time, versus 0% for Low severity — even though Critical incidents are resolved fastest in absolute terms (9.8 days average). This is because Critical SLA targets are only 3 days, so speed that looks good in isolation is still a governance failure relative to the commitment made for the highest-escalation level data shows Board/Executive-tier incidents breach SLA 60% of the time overall. This directly undermines the credibility of the escalation and reporting model built in Part A4 — if the incidents meant to trigger the fastest, most senior response are the ones most likely to run late, the escalation path is not functioning as designed.

Governance significance

CISO (incident response capacity) and Board Risk Committee (SLA policy realism and oversight) introduce a dedicated incident-commander fast-track for Critical/High severity cases with pre-approved resourcing, and review whether the 3-day Critical SLA target is operationally realistic or needs revision.

Recommended action

Owner / Success metric

Owner: CISO. Success metric: Critical-severity SLA breach rate below 20% within two quarters.

Insight #2: Third-party involvement carries a significant cost premium

Third Party Involved	Avg Cost USD
No	52002
Yes	73700

Finding

Incidents involving a third party cost 41.7% more on average (\$73,700 vs \$52,000) than incidents that do not, despite third-party incidents representing a minority (43 of 180) of the total caseload.

Governance significance

This mirrors the vendor-coordination failure modeled in Part A5: third-party incidents are costlier partly because internal escalation paths are not designed around vendor-originated notifications, so containment and response are slower and more expensive.

Accountable role(s)

Chief Risk Officer (third-party risk acceptance) and business-unit vendor owners (e.g., HR, Procurement)

Data Dictionary Analysis Template D1_Core_Analysis D2_Advanced_Analysis **D3_CISO_Insights**

